حزمة المقرر الجامعي

تدريس الأمن السيبراني في الجامعة

مقرر من ١٤ أسبوعًا و٣ ساعات معتمدة في أمن الحاسوب والشبكات لطلاب السنة الثالثة في علوم الحاسوب أو هندسة الحاسوب. المتطلبات السابقة: البرمجة، والرياضيات المتقطعة، والشبكات. ترتكز محاضرات دَرسي الأربع على الأسابيع ٢ و٥ و٧ و٩.

نواتج التعلّم

١. تطبيق مبادئ التصميم الآمن الكلاسيكية لتقييم نظام.

٢. إعداد نموذج تهديدات STRIDE مع إجراءات حد مرتّبة بالأولوية.

٣. شرح ما يضمنه كلٌّ من تبادل المفاتيح والتشفير والتوقيع.

٤. إعداد تخزين كلمات السر وتحقق من الهوية مقاوم للتصيّد.

٥. إجراء تمارين هجومية بصورة قانونية وأخلاقية داخل نطاق موقّع.

الخطة الدراسية في ١٤ أسبوعًا

الأسبوع	الموضوع	داخل القاعة وخارجها
١	أهداف الأمن والقانون والأخلاقيات	توقيع قواعد الاشتباك
٢	مبادئ التصميم ونمذجة التهديدات	المعمل ١: STRIDE على بوابة المقرر
٣	التشفير المتماثل	مجموعة المسائل ١
٤	نظرية الأعداد للتشفير	تمارين ورقية
٥	ديفي وهيلمان وRSA	المعمل ٢: هجوم الوسيط
٦	البنية التحتية للمفاتيح والشهادات وTLS	مجموعة المسائل ٢
٧	التجزئة وتخزين كلمات السر	المعمل ٣: كسر جداول اصطناعية
٨	التحقق من الهوية والتحقق المتعدد	امتحان منتصف الفصل
٩	المعامل الهجومية والإفصاح المسؤول	المعمل ٤: النطاق المعزول
١٠	أمن تطبيقات الويب	تحديات التقاط العلم ١ و٢
١١	هجمات الشبكات ودفاعاتها	تحديات التقاط العلم ٣ و٤
١٢	الهندسة الاجتماعية والتصيّد	تحدي التقاط العلم ٥ والتقارير
١٣	الاستجابة للحوادث	تمرين محاكاة على الطاولة
١٤	المراجعة وعروض المشاريع	الامتحان النهائي

مخطط شرائح المحاضرات

المحاضرة ١: المبادئ وSTRIDE

- اختراق سببه إعداد افتراضي
- مبادئ Saltzer وSchroeder الثمانية
- مخططات مسار البيانات وحدود الثقة
- تهديدات STRIDE وخصائصها
- النشاط: نمذج البوابة

المحاضرة ٢: التشفير بالمفتاح العام

- مشكلة توزيع المفاتيح
- ديفي وهيلمان بأعداد صغيرة
- التشفير والتوقيع بـ RSA
- لماذا يهم الحشو
- النشاط: أليس وبوب وإيف

المحاضرة ٣: كلمات السر والتحقق من الهوية

- خصائص التجزئة وأثر الانهيار
- لماذا تفشل التجزئة السريعة
- الملح وArgon2id
- الرسائل النصية والتطبيقات ومفاتيح FIDO2
- النشاط: اكسر جدولًا وهميًا

المحاضرة ٤: الأخلاقيات والمعامل والتقاط العلم

- الاختبار المصرّح به مقابل الاختراق
- قواعد الاشتباك
- بناء نطاق معزول
- أعلام لكل طالب وتقارير
- النشاط: صمّم مسابقة التقاط علم عادلة

مجموعة المسائل

١. مجلد مشترك يقرؤه كل الموظفين لأن إعداده كان أسهل. سمِّ مبدأين منتهكين واقترح إصلاحًا.

٢. لمسار دخول (المتصفح ← خادم الويب ← قاعدة البيانات)، اذكر تهديدًا لكل حرف في STRIDE.

٣. مع $p = 23$ و$g = 5$، تختار أليس $a = 6$ ويختار بوب $b = 15$. احسب A وB والمفتاح المشترك.

٤. مع $p = 5$ و$q = 11$ و$e = 3$، أوجد d وشفّر $m = 2$.

٥. يختبر مهاجم 10^{10} تخمين SHA-256 في الثانية. كم يستغرق تجريب قائمة من 10^{8} كلمة على 10^{4} حساب غير مملّح، وعلى 10^{4} حساب مملّح؟

٦. أبلغ طالب عن صفحة إدارة مكشوفة على موقع الجامعة. حدّد الاستجابة المتوقعة في المقرر.

الحلول

١. الافتراضات الآمنة وأقل صلاحية. امنع افتراضيًا وامنح القراءة لكل مجموعة تحتاجها.

٢. S: سرقة كعكة الجلسة. T: تعديل معاملات الطلب. R: غياب سجل تدقيق الدخول. I: حقن SQL يسرّب التجزئات. D: إغراق الدخول. E: غياب التفويض على مسارات المدير.

٣. $A = 5^{6} \bmod 23 = 8$، و$B = 5^{15} \bmod 23 = 19$، والمفتاح $= 19^{6} \bmod 23 = 2 = 8^{15} \bmod 23$.

٤. $n = 55$، و$\varphi(n) = 40$، و$d = 27$ لأن $3 \times 27 = 81 \equiv 1 \bmod 40$. و$c = 2^{3} \bmod 55 = 8$.

٥. غير مملّح: تُجزّأ القائمة مرة واحدة، $10^{8} / 10^{10} = 0.01$ ثانية. مملّح: مرة لكل حساب، $10^{4} \times 0.01 = 100$ ثانية. يضاعف الملح الجهد بعدد الحسابات، وتضاعفه التجزئة البطيئة أكثر.

٦. التوقف عن الاختبار، وعدم الوصول أكثر، والإبلاغ سرًا للمحاضر وأمن تقنية المعلومات بالتفاصيل، والحفاظ على السرية حتى الإصلاح، وتقدير الطالب على الإفصاح المسؤول.

ورقة المعمل: المعمل ٣: تخزين كلمات السر تحت الهجوم

الهدف

قياس كيف يغيّر الملح والتجزئة البطيئة تكلفة المهاجم باستخدام حسابات اصطناعية فقط في جهاز افتراضي معزول.

الخطوات

١. ولّد ١٠٠٠ حساب اصطناعي من قائمة كلمات عامة.

٢. خزّنها بـ SHA-256 وSHA-256 مملّح وArgon2id.

٣. أجرِ هجوم القاموس نفسه على كل جدول وسجّل التخمينات في الثانية.

٤. اضبط Argon2id بحيث يستغرق التحقق الواحد نحو ١٠٠ مللي ثانية.

٥. اكتب سياسة تخزين وتحقق متعدد لنظام جامعي.

المطلوب تسليمه

جدول نتائج والمعاملات المضبوطة وسياسة من صفحة واحدة.

معيار التقييم

المعيار	ممتاز	جيد	قيد التطور	لم يتحقق بعد
تحليل التهديدات	تهديدات قليلة بلا بنية	STRIDE مطبّق جزئيًا	كل العناصر مغطّاة	مغطّاة ومرتّبة حسب الخطر
التفكير التشفيري	يخلط بين العمليات	يحسب بصورة صحيحة	يذكر الضمانات	يكتشف عيوب البروتوكول
الإصلاح الدفاعي	لا يوجد	عام	محدد وصحيح	محدد ومختبر ومبرَّر
السلوك المهني	خارج النطاق	داخل النطاق	داخل النطاق وموثّق	موثّق مع إفصاح مسؤول

قائمة القراءات

Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. Proceedings of the IEEE, 63(9), 1278–1308.

مبادئ التصميم.

Shostack, A. (2014). Threat Modeling: Designing for Security. Wiley.

STRIDE في التطبيق.

Diffie, W., & Hellman, M. E. (1976). New directions in cryptography. IEEE Transactions on Information Theory, 22(6), 644–654.

تبادل المفاتيح بالمفتاح العام.

Rivest, R. L., Shamir, A., & Adleman, L. (1978). A method for obtaining digital signatures and public-key cryptosystems. Communications of the ACM, 21(2), 120–126.

.RSA

Katz, J., & Lindell, Y. (2020). Introduction to Modern Cryptography (3rd ed.). CRC Press.

النص الأساسي الدقيق.

Anderson, R. (2020). Security Engineering (3rd ed.). Wiley.

دراسات حالة لإخفاقات حقيقية.

Grassi, P. A., et al. (2017). NIST Special Publication 800-63B: Digital Identity Guidelines, Authentication and Lifecycle Management. NIST.

إرشادات كلمات السر وأدوات التحقق.

Joint Task Force on Cybersecurity Education (2017). Cybersecurity Curricula 2017 (CSEC2017). ACM/IEEE-CS/AIS SIGSEC/IFIP WG 11.8.

إرشادات المناهج.